Corridor: Security Self-Assessment

Fintechathon 2026, International Track, Topic C. Version 1.0, October 2026.

1. Principles

1. **The model proposes, rules decide, the student confirms.** No output of a language model can move money by itself.
2. **Least privilege by default.** The agent starts in “act after I confirm” mode. Automatic actions are opt-in, small, and limited to the student’s own money.
3. **Untrusted input stays data.** Documents, pasted messages and tool results never become instructions.
4. **Check twice.** Every action is evaluated when proposed and again at the moment of confirmation.
5. **Everything is recorded.** A tamper-evident log records every request, decision and execution.
6. **Collect little, show less.** Account numbers are masked; parent mode shows status, never spending.

2. Permission tiers (implemented in `src/policy.js`)

Tier	Name	What it allows	Confirmation	Tools
T0	Read	Look at balances, budget, wishlist, quotes, documents, rules. No side effects.	None	get_wallet, get_budget, get_wishlist, check_purchase, trip_readiness, compare_routes, check_fx_quota, assess_scam_risk, review_document, get_credit_plan
T1	Plan	Build plans and edit the student’s own plans (wishlist). Never moves money.	None	add_wishlist_item, add_expense, add_income, plan_tuition_payment
T2	Act	Move, convert, save or spend money in the sandbox; create standing rules.	Student presses Confirm. Exception: when the student enables automatic mode, `save_to_pot`, `convert_currency` and `send_money` to a verified payee may run without a click if the amount is within the automatic	send_money, convert_currency, buy_wishlist_item, save_to_pot, set_auto_save, set_rate_rule, pay_tuition

Tier	Name	What it allows	Confirmation	Tools
			limit (default CAD 100) and no warning was raised. Purchases, tuition and standing rules always need a click.	
T3	Forbidden to the agent	Change autonomy or limits, add or verify payees, export personal data.	Only the student, in the Safety screen. Any agent call is denied and logged.	change_settings, add_payee, export_personal_data

The nine checks applied to every T2 action

#	Check	Effect when it fails
1	Autonomy setting is not “advise only”	Block
2	Recipient is a verified payee (school registry or student-verified)	Block
3	Any supporting document passed integrity checks (no hidden text, no instructions to the AI, account matches registry)	Block
4	Scam shield on the conversation context	High risk: block. Medium: warning on the card
5	No structuring, by stated intent or by pattern (several sub-threshold transfers in a day)	Block
6	Per-transfer cap and daily outbound cap set by the student	Block
7	Sufficient funds	Block
8	Home-country FX rules (China annual quota)	Block for non-documented purposes; tuition above quota requires the student’s attestation
9	Budget impact of purchases; large-transfer reporting notice	Warning only

The confirmation (`Session.confirm`) re-runs all nine checks with the state at that moment. Example covered by a test: a transfer proposed in a normal conversation is blocked at confirmation if a scam call is pasted in between.

Separation of duties in code

- The agent reaches the sandbox only through `Session.callTool(name, args, actor)`.
- `confirm`, `reject` and `updateSettings` are not tools. They are called only by the interface on a human click; `updateSettings` refuses any actor other than `user`.

- Interface buttons (for example “Buy at this price”) call the same tools as the agent and pass through the same guard.

3. Threats and controls

Threat	Control	Test
Indirect prompt injection in a document (hidden text telling the AI to pay another account)	Hidden-text and instruction detection, registry comparison, documents wrapped as untrusted data, guard rejects mismatched accounts even if the model passes them	`poisoned invoice is detected`; scenario `liwei_poisoned_invoice` simulates a fully compromised model calling `pay_tuition` with the attacker’s account: blocked
Model hallucinates or is jailbroken into moving money	T2 tools only propose; human confirmation; caps; verified payees	`money never moves without confirmation by default`
Agent escalates its own permissions	Settings are T3; `updateSettings` accepts only the user actor	`T3 actions are always denied`, `the agent cannot change its own settings`
Social-engineering scams (fake police, embassy, bank security, SMS code, virtual kidnapping)	Multilingual scam shield, block plus advice with local emergency numbers, re-check at confirmation	`scam shield flags…`, `the guard re-checks at confirm time`, scenario `christina_scam`
Invoice fraud (“our bank details have changed”)	Changed-details detection; payment only to registry account	scenario `liwei_poisoned_invoice`
Structuring and FX quota evasion	Intent and behavioural detection; refusal with the legitimate route	`structuring requests are detected…`, scenario `liwei_structuring`
Time-of-check to time-of-use changes	Full re-evaluation at confirmation	`the guard re-checks at confirm time`
Tampering with history	SHA-256 hash chain; data deep-copied on write	`audit log detects tampering`
Leaking personal data in logs	Account numbers masked before logging; long texts truncated	`account numbers are masked in the audit log`
Over-sharing with family	Parent mode off by default, explicit opt-in, shows obligations, savings progress and transfers from home only	scenario `guardrails`
Runaway automation	Automatic mode opt-in, per-action limit, restricted to three action types, purchases and rules excluded	`auto mode runs small actions to own pots, never purchases`

4. Known risks and limitations

#	Risk	Severity	Status and mitigation path
1	Keyword-based detectors (scam, structuring, injection) can be evaded by rephrasing or other languages	Medium	The guard's structural checks (verified payees, caps, confirmation, registry match) still apply. Next: add a model-based classifier as a second opinion, never as the only control.
2	Sandbox only: no real authentication, device binding or strong customer authentication	High for production	Out of scope for the prototype. Production needs bank-grade login, device binding and step-up authentication (for example biometric approval) for T2 actions.
3	Compliance thresholds marked `verified: false` (China quota details, Kazakhstan document threshold, FINTRAC wording)	Medium	Flags are visible in `src/data.js`; legal review per jurisdiction before real use.
4	Simulated fees and rates; third-party sources for some product fees (Alipay)	Medium	Labelled in the interface and code; production would use provider APIs and a live rate feed.
5	Model may misstate a number in prose even though tools are correct	Low to medium	Instructions require tool-sourced numbers; confirmation cards show the guard's own summary, so the student confirms the real figures.
6	Browser state is in memory; a refresh resets the sandbox	Low	Intended for the demo. Production would use a server-side ledger.
7	Hash chain proves integrity within one log, not against deletion of the whole log	Low	Production: anchor periodic chain heads externally (write-once storage).
8	Free-text wishlist names and memos could carry injection attempts into later model calls	Low	Tool outputs are data; T2 actions still require confirmation and pass the guard.
9	Advice on insurance, credit and legal rules could be taken as professional advice	Low	Every such output says general information and "check your plan"; no product recommendations.

5. Privacy

- Data minimisation: the agent sees balances, budget categories and obligations needed for the task; account numbers are masked to the last four digits.
- Consent: parent mode requires the student's explicit opt-in and excludes spending details.
- Frameworks considered: Canada's PIPEDA and Quebec's private-sector privacy act as amended by Law 25 (consent, minimisation, access logs). Requirements in Kazakhstan and China would be added through the country packs.

6. How to verify

```
npm test             # 37 tests including all controls above
npm run evidence     # evidence/sandbox-log.jsonl and transcripts for 11 scenarios
```

In the web app: Safety screen shows the tiers, the student's limits and the live audit log with chain verification. Demo controls include a scam call and a poisoned invoice.